

CONFIGURING & SECURING CASELIGHT

Administrator Guide

Set up users, tailor the system to your programs without code, and operate its security controls — everything under Manage and the admin surfaces.

Lighthouse Nonprofit Technologies · CaseLight · AGPL-3.0 — screens show synthetic demo data only

CaseLight — Administrator Guide

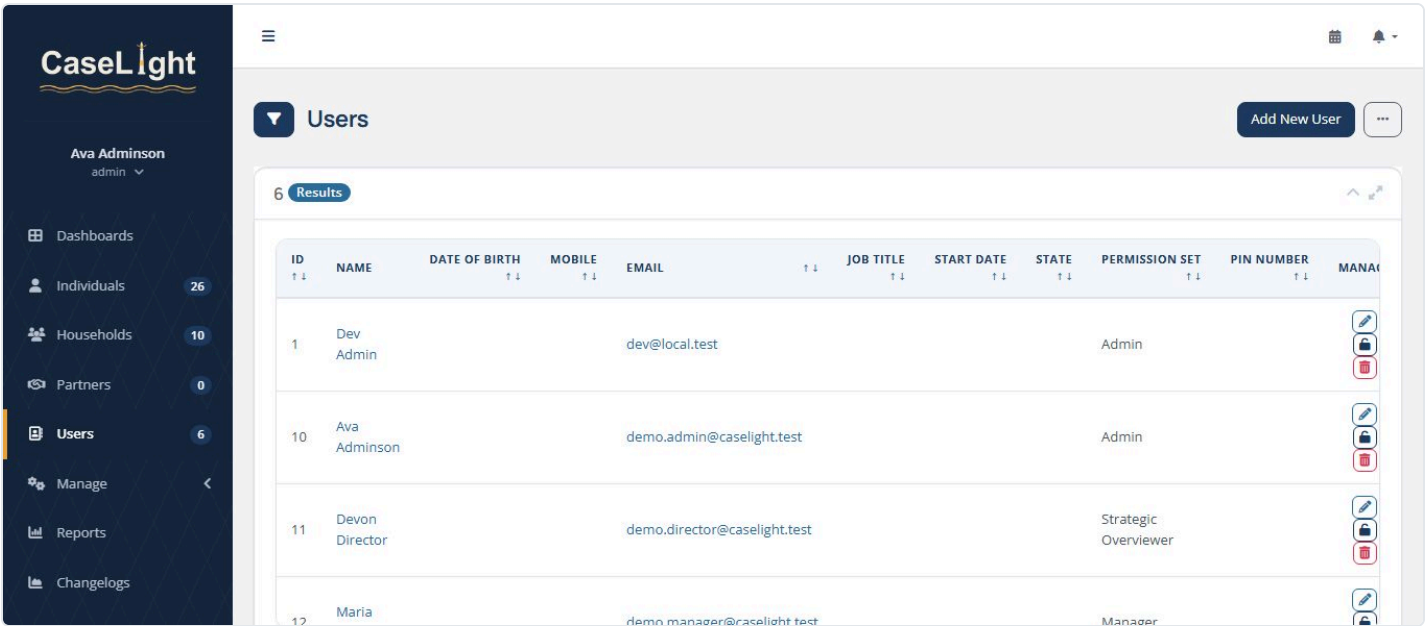
Configuring & securing CaseLight — set up users, tailor the system to your programs without code, and operate its security controls: everything under **Manage** and the admin surfaces.

All screenshots in this guide show synthetic demo data — fictional names, addresses, and records.

1 · Users & access

Under **Users**, add a staff account for each person and assign a role — the role decides what they can see and do (see the User Guide's role table). Beyond add/edit/export:

- **Manager assignment** — each case worker's record names their manager; that hierarchy is what scopes a manager's view to their team's caseloads. Keep it current when teams change.
- **Disable, don't delete** — when staff leave, disable the account. A disabled account cannot sign in, but every note, task, and change it made stays attributed. The Access Review report flags disabled staff who still hold caseloads so those can be reassigned.
- **Google Calendar sync** — a per-user opt-in on the user record; off by default. The internal calendar works either way.
- **User custom fields** — users can carry custom forms too (certifications, training records), designed in the same form builder.



Users — one account per staff member.

Access Review — periodic recertification

The **Access Review** report (AC-2) lists every account with its role, last sign-in, MFA and passkey status, and whether it's locked or disabled. It flags disabled staff who still hold caseloads, and summarizes the least-privilege and authorization shadow windows. Export to CSV for your records.

CaseLight

Ava Adminson
admin

Dashboards

Individuals 26

Households 10

Partners 0

Users 6

Manage <

Reports

Changelogs

Access Review

Security Enforcement

Access Review

Periodic recertification (AC-2(j)). PER TENANT - run once per subdomain to cover all staff.

Export CSV

NAME	EMAIL	ROLE	LAST SIGN IN	COUNT	MFA	PASSKEYS	LOCKED	DISABLED	CREATED
Ava Adminson	demo.admin@caselight.test	admin	2026-07-30 19:16	239	off	0			2026-07-08
Dev Admin	dev@local.test	admin	2026-07-29 18:14	114	on	1			2026-06-21
Devon Director	demo.director@caselight.test	strategic overviewer	2026-07-30 19:16	11	off	0			2026-07-08
Maria Manders	demo.manager@caselight.test	manager	2026-07-08 17:00	1	off	0			2026-07-08
QA Totp	qa.totp@caselight.test	admin	2026-07-12 09:41	4	on	0			2026-07-11
Wes Worker	demo.worker@caselight.test	case worker	2026-07-30 19:16	17	off	0			2026-07-08

Disabled Staff Still Holding Caseloads

These accounts cannot sign in (disabled) but still have clients assigned. Reassign their caseloads so work is not routed to a dead account.

None — no disabled account holds a caseload.

Least-Privilege Shadow Divergences

AC-6 shadow window (enforcement OFF). How often the narrowed rules WOULD have denied access, per staff member, over the last 14 days. Review before enabling enforcement.

No shadow divergences recorded yet.

Authorization-Cutover Shadow (AC-3)

Global authorization cutover shadow window (enforcement OFF). Actions that WOULD fail the mandatory authorization check, by controller/action/role, over the last 14 days. Review before flipping enforce_authorization.

No authorization-cutover divergences recorded yet.

Access Review — recertify accounts and catch orphaned caseloads.

2 · Configure without code: the form builder

Rather than editing the data model, add **custom forms** (attachable to individuals, households, users, or partners) with a drag-and-drop builder under **Manage** → **Form Builder**.

The form builder — choose type, frequency, and the form's sensitivity, then drag in fields.

Every form carries a **sensitivity**, set at design time:

- **Standard** — any authorized reader of the record.
- **Restricted** — caseload- or role-scoped readers only.
- **Emergency only** — hidden unless a break-glass grant is active (see §6).

Because sensitivity is chosen when the form is designed, a brand-new form can never accidentally expose data — it inherits an explicit classification from the start.

Designing good forms. Two rules of thumb carry most of the weight:

- **Tracking form or custom form?** Data that belongs to a *program* (a recurring check-in that only makes sense while enrolled) is a tracking on that program stream (§3). Data that belongs to the *person or household* regardless of program is a custom form. Ask: "would we still record this if they left the program?"
- **Pick widgets for the analysis, not just the entry.** Selects, radio groups, and checkboxes produce countable, filterable data (checkboxes = multi-select, radios = one answer); free-text areas produce narrative that Advanced Search can't aggregate. Don't re-collect identifying details the record already holds, and keep forms short — every field is work for frontline staff on every entry.

Individual forms appear on the person's **Forms** tab; household forms on the household's.

3 · Program streams

Define the programs your organization actually runs under **Manage** → **Programs**. Each stream is enrollable, has its own custom form, and supports recurring, date-stamped trackings.

Before building anything, sketch your organization's program flow on paper — where people enter, the decision points, where they exit. It doesn't have to be perfect, just good enough to name the streams. Each stream then gets: program details, optional **enrollment rules** (conditions a person must meet, with a preview of who currently qualifies), an **enrollment form**, one or more **tracking forms**, and an **exit form**. Editing a stream that already has enrollments shows a warning first — form changes affect everyone enrolled, so coordinate with whoever owns that program's reporting.

CaseLight

Ava Adminson
admin

Dashboards

Individuals26

Households10

Partners0

Users6

Manage

Agencies

Domains

Domain Groups

Donors

Referral Sources

Quantitative Types

Progress Note

Form Builder

Programs

What's New

Reports

Changelogs

Access Review

Programs

Add New Program

Our Programs

Program Library (other organizations)

NAME	DOMAINS	STATUS	ENROLLED	MAXIMUM PROGRAM ENROLLMENT	ACTION
Adult Education / ESL		Completed	1		  
Benefits		Completed	9		  
Childcare		Completed	1		  
Employment		Completed	15		  
Housing		Completed	10		  
Immigration / Legal		Completed	15		  
K-12 Education		Completed	11		  

Program streams — the enrollable programs behind every case.

4 · Assessment domains & groups

The assessment engine scores needs across **life domains**, organized into **domain groups**. Configure both under Manage, and set each domain's **sensitivity** so the most protected domains stay restricted.

CaseLight

Ava Adminson
admin

Dashboards

Individuals 26

Households 10

Partners 0

Users 6

Manage

Agencies

Domains

Domain Groups

Donors

Referral Sources

Quantitative Types

Progress Note

Form Builder

Programs

What's New

Reports

Changelogs

Access Review

6 Domain Groups

Add New Domain Group

DOMAIN GROUP NAME	DESCRIPTION	MANAGE		CHANGELOG
1. Housing & Basic Needs				View
2. Economic Self-Sufficiency				View
3. Language & Education				View
4. Health & Well-Being				View
5. Legal & Immigration				View
6. Community & Safety				View

Domain groups.

CaseLight

Ava Adminson
admin

Dashboards

Individuals 26

Households 10

Partners 0

Users 6

Manage

Agencies

Domains

Domain Groups

Donors

Referral Sources

Quantitative Types

Progress Note

Form Builder

Programs

What's New

Reports

Changelogs

Access Review

12 Domains

Add New Domain

Domains : 1A (Housing Stability)

Score 1

Score 2

Score 3

Score 4

Changelog

Goal: The household has safe, stable, affordable housing.

Sample questions:

- What is the household's current housing situation?
- Is the rent affordable relative to income?
- Is the housing safe and adequate for the family size?
- Is the lease or tenancy secure?

Score interpretations (1 = in crisis → 4 = self-sufficient):

1: In crisis — homeless or in emergency / temporary shelter.

2: At risk — housed but unstable; at risk of eviction, overcrowded, or unaffordable.

3: Stable — safe, adequate housing with a secure lease; rent is manageable.

4: Self-sufficient — housing is stable, affordable, and maintained without ongoing assistance.

Domains : 1B (Food Security)

Score 1

Score 2

Score 3

Score 4

Changelog

Goal: The household has reliable access to enough nutritious food.

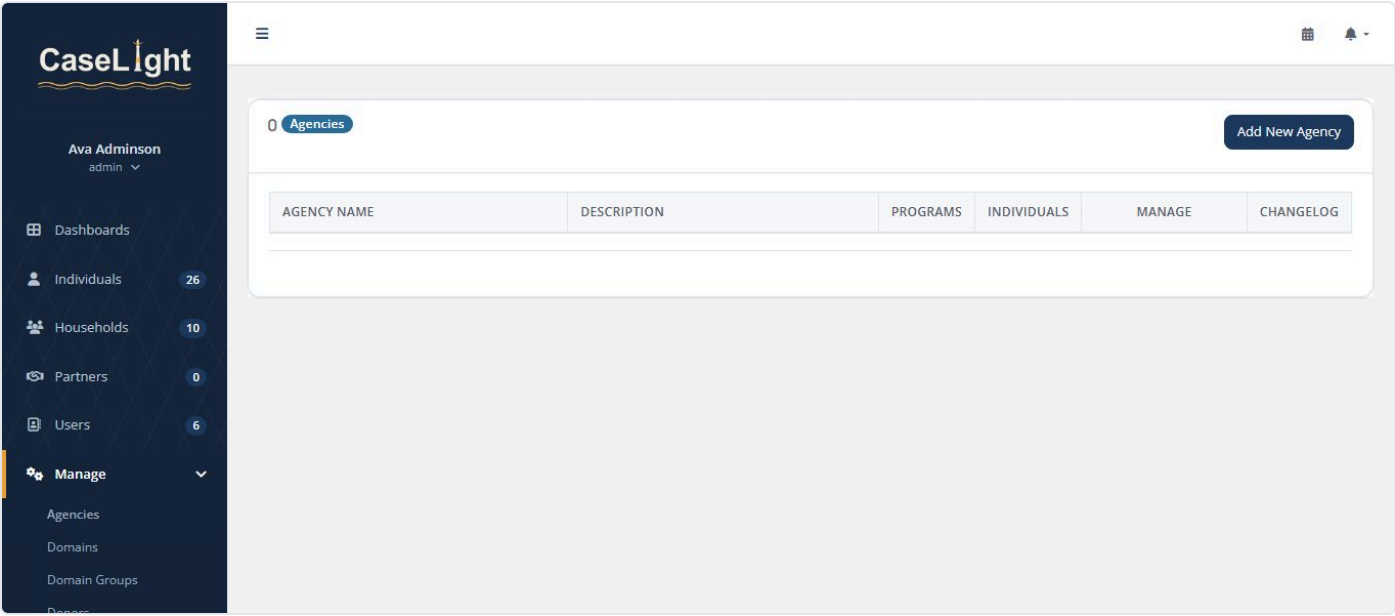
Sample questions:

- Does the household have enough food throughout the month?
- Are they enrolled in CalFresh / food assistance if eligible?
- Can they shop for and prepare culturally appropriate food?

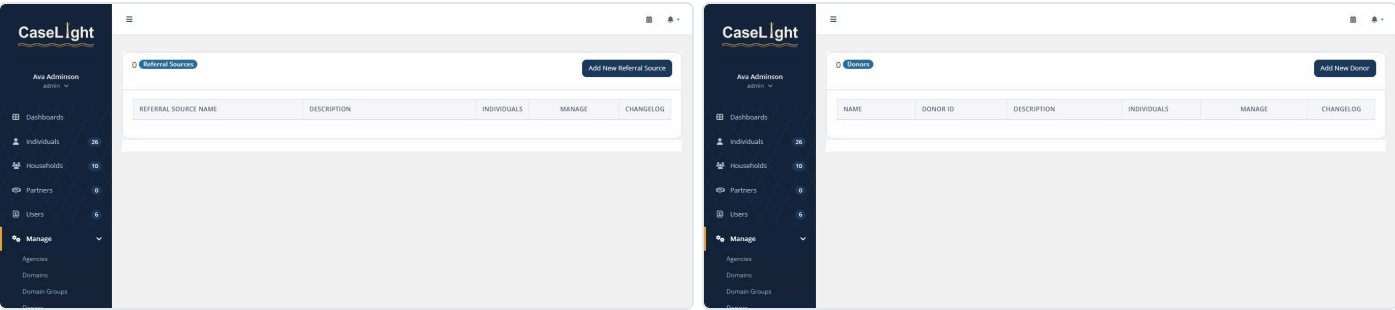
Domains (with sensitivity).

5 • Reference data

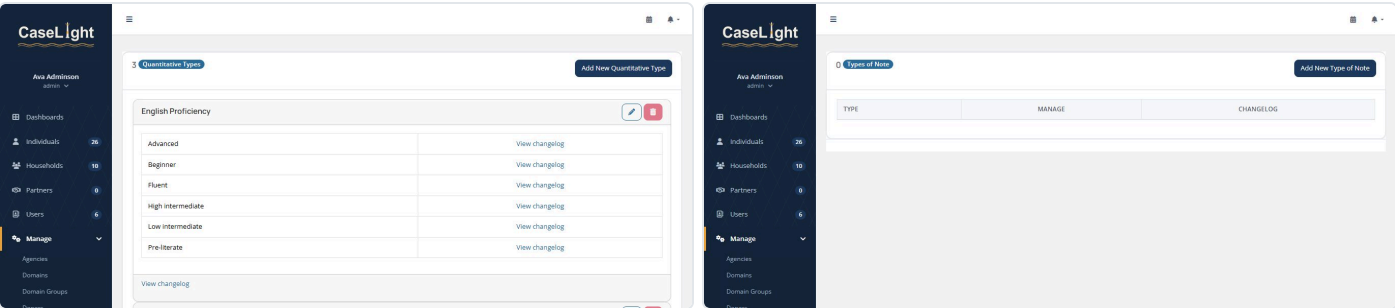
The lists that populate dropdowns and organize your work — all editable under **Manage**. Keep them tidy and every record downstream stays consistent.



Agencies — partner and referring organizations. Link each agency to the programs it works with (the Programs column links to each program's page), and click the agency's name to see its individuals, pre-filtered. (Departments are hidden for the pilot.)



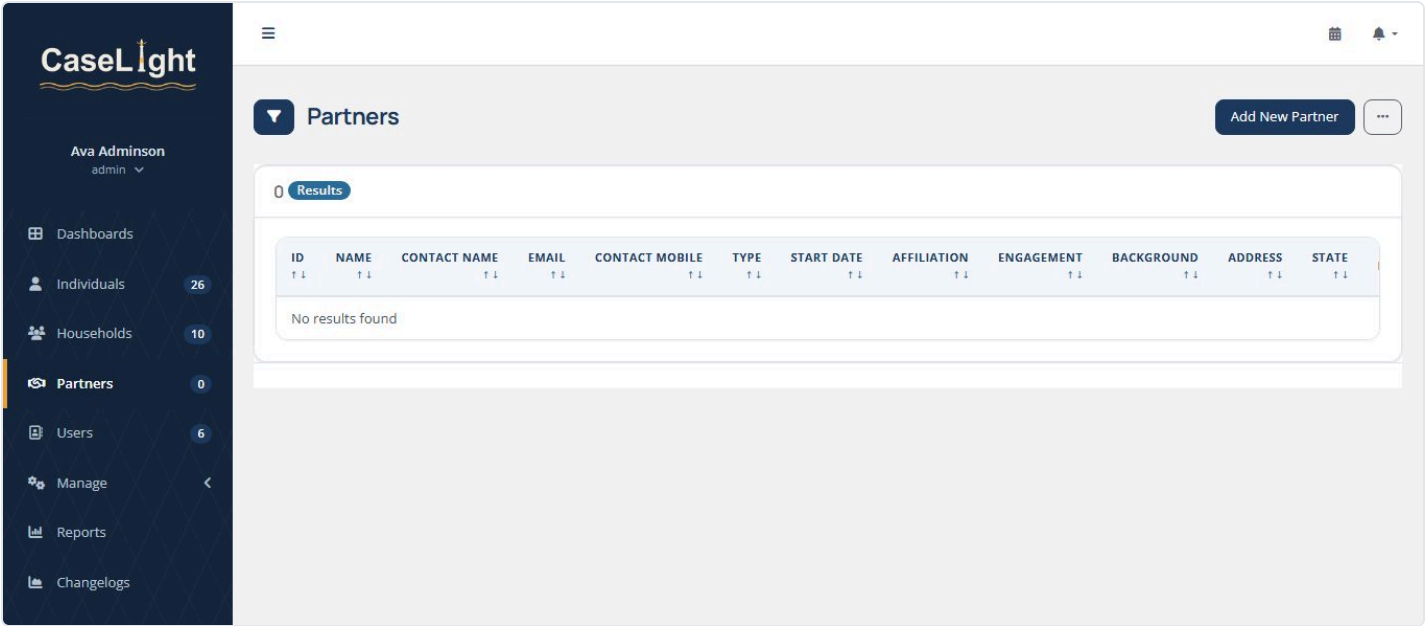
Referral sources — how clients reach you. • Donors — funding sources for reporting.



Quantitative types — reference lists staff pick from on the individual form (each type carries a description shown as help text, and a single- vs multi-select setting). • Types of Note — categories for progress notes.

Partners

External **Partners** (agencies you coordinate with) get their own records and custom forms, tracked separately from the individuals you serve.



Partners.

6 · Security enforcement & break-glass

The **Security Enforcement** panel turns live security controls on or off for your organization, each mapped to a NIST 800-53 control, and each showing a **shadow window** — what the stricter rule *would have* denied — so you can review impact before enabling.

Since **2026-07-26** the three authorization controls (global authorization, least-privilege narrowing, and the tenant-boundary tripwire) are **on by default in production** — the flip was made after the shadow window recorded zero divergences. Your panel settings still override the default in either direction, and every change is audited. Account-affecting controls (like requiring MFA) follow the **enforcement-window policy**: they stay off until your staff have had time to enroll their authentication of choice.



Security Enforcement

Runtime control of this organization's Phase-5 security enforcement flags.

Scope: this organization only (cases)

These switches ENABLE or DISABLE live security enforcement for THIS organization. Review the shadow findings below BEFORE enabling. Turning on authorization enforcement makes every action require explicit authorization.

Global authorization enforcement (AC-3)

shadow / off system default

Requires every controller action to explicitly authorize. When enabling, review the authorization-cutover shadow below — any action listed WOULD return 403.

Use system default

Authorization-cutover shadow — would-403, last 14 days (review before enabling)

No shadow divergences recorded yet.

Least-privilege narrowing (AC-6)

shadow / off system default

Scopes progress-note and version reads to need-to-know. When enabling, review the least-privilege shadow below — any row listed WOULD be denied.

Use system default

Least-privilege shadow — would-deny, last 14 days (review before enabling)

No shadow divergences recorded yet.

Tenant-boundary tripwire (SC-7)

ENFORCING persisted override

Refuses any request whose data schema does not match the host tenant. Under normal operation zero mismatches are expected.

Enforcing

0 tenant-mismatch event(s) in the last 14 days (0 expected).

Require two-factor authentication (all users) (IA-2(1))

system default

When On, every signed-in user without 2FA is redirected to enroll before continuing. The default nudges only privileged (admin/manager) accounts. This is an enrollment prompt, never a lockout — the enrollment page and this settings page stay reachable.

Use system default

Idle session timeout (AC-12)

Minutes of inactivity before a session is invalidated and re-authentication is required. Blank uses the system default (30 minutes). Allowed range 1-1440.

Idle timeout (minutes)

System default (30)

Leave blank to use the system default (30).

Account lockout threshold (AC-7)

Consecutive failed sign-ins before an account is locked, and how long until it auto-unlocks. Blank uses the system defaults (10 attempts / 60 minutes).

For safety, the attempt threshold cannot be set below 3 — a lower value could lock out administrators after a couple of typos.

Max failed attempts (minimum 3)

Lockout max attempts

Auto-unlock after (minutes)

Lockout unlock in minutes

Password expiry / rotation (IA-5)

Maximum password age in days. When set, a user whose password is older is prompted to change it at next login (never locked out; the change-password page requires the current password and enforces complexity + no-reuse). Blank means passwords never expire (recommended per NIST 800-63B unless a policy requires rotation).

Max password age (days)

No expiry (default)

Leave blank for no expiry (the default).

Inactive-account auto-disable (AC-2(3))

Days of inactivity (no sign-in) before a staff account is automatically disabled by the daily maintenance run. A disabled account cannot sign in but keeps its records and can be re-enabled from its user page. The last enabled administrator is never auto-disabled. Blank means the daily run only reports would-be candidates and disables nobody.

Disable after inactive (days, minimum 30)

Off — report only (default)

Leave blank to keep auto-disable off (the daily run stays report-only).

Save enforcement settings

Open the full Access Review report

Last changed by dev@local.test at 2026-07-01 11:24

Security Enforcement — per-organization control toggles.

Control	NIST	What it does
Global authorization	AC-3	Require every action to authorize explicitly.
Least-privilege narrowing	AC-6	Scope reads to need-to-know.
Tenant-boundary tripwire	SC-7	Refuse any cross-tenant request.
MFA & idle timeout	IA-2 · AC-12	Require MFA; invalidate idle sessions.
Lockout & password expiry	AC-7 · IA-5	Lock after failed sign-ins; rotate passwords.
Inactive-account auto-disable	AC-2(3)	Disable dormant accounts automatically.

Break-glass emergency access

When a genuine life-safety need requires an emergency-only field, an eligible worker can self-elevate for **one hour** — with a mandatory reason and the audit record written *first*. Access is scoped to the specific record, expires automatically, and is fully logged.

7 · Data protection & privacy

CaseLight is hardened at the application layer toward **NIST 800-53 Moderate** and **SOC 2** (Security, Confidentiality, Privacy), and aligns with the **HIPAA Security Rule**.

- **Field-level sensitivity** — Standard / Restricted / Emergency-only on forms and domains; records mask what a role isn't cleared to see.
- **Encryption at rest** — sensitive PII is encrypted in the database across multiple tiers.
- **Append-only audit trail** — reads and changes logged to a separate, tenant-isolated store, with change history and retention.
- **Tenant isolation** — each organization is its own subdomain and database schema.
- **Data lifecycle** — retention/deletion routines, guarded and audited deletion, and a subject-access export.

Data-lifecycle operations (command line)

Three operator tasks cover the lifecycle obligations; each is dry-run by default and requires `CONFIRM=1` (or an explicit tenant/client) to act:

- **Subject-access export** — `rake privacy:subject_access_export TENANT=<t> CLIENT=<id>` produces everything held about one person as a reviewable bundle under `tmp/exports/`, and writes an audit-log entry recording the export.
- **Retention** — `rake retention:report` shows what is past policy; `rake retention:purge_versions / retention:purge_client_histories` purge aged change history (a `DAYS` floor guards against accidentally aggressive runs).
- **Deletion** — client deletion from the Actions menu is guarded and audited; it removes the record and its dependents, while the append-only audit log keeps the fact that a deletion happened.

Deploy and box operations (the bootstrap script, encryption backfills, and their invariants) are documented in [../OPERATIONS.md](#).

The full compliance package — System Security Plan, SOC 2 control matrix, policies, POA&M, and a reproducible `rake compliance:evidence` bundle — lives in `docs/compliance/`. Data-handling posture and the production gate for real client data are in `SECURITY.md`. **Pilot data is synthetic only.**